Footprinting & Reconnaissance Report

Week 2 | Project Module 1 — Multiple Kali Tools

Target: networkwalks.com

Prepared in: Kali Linux 2026.2 (VirtualBox)

Tools used: whois · whatweb · nslookup · curl · wafw00f · dnsrecon

For educational purposes only — authorized lab exercise

1. Background & Objective

Reconnaissance, also called footprinting, is the first step of any real attack or authorized security assessment. Before touching a target, an assessor quietly collects as much public information about it as possible: who owns the domain, its real IP address, its hosting provider, the technologies running on its web server, its DNS and mail records, and whether a firewall is protecting it. All of this comes from information the target has already made public, so the target is never directly contacted and never knows it is being studied.

This report documents six passive and semi-passive footprinting tasks performed against the live website networkwalks.com, using tools built into Kali Linux. Each tool reveals a different piece of the target, and together they build a composite profile that would normally serve as the foundation for later scanning and testing phases.

Tools used

- whois — domain registration lookup
- whatweb — web technology fingerprinting
- nslookup — DNS resolution
- curl -I — HTTP response header inspection
- wafw00f — Web Application Firewall detection
- dnsrecon — full DNS record enumeration

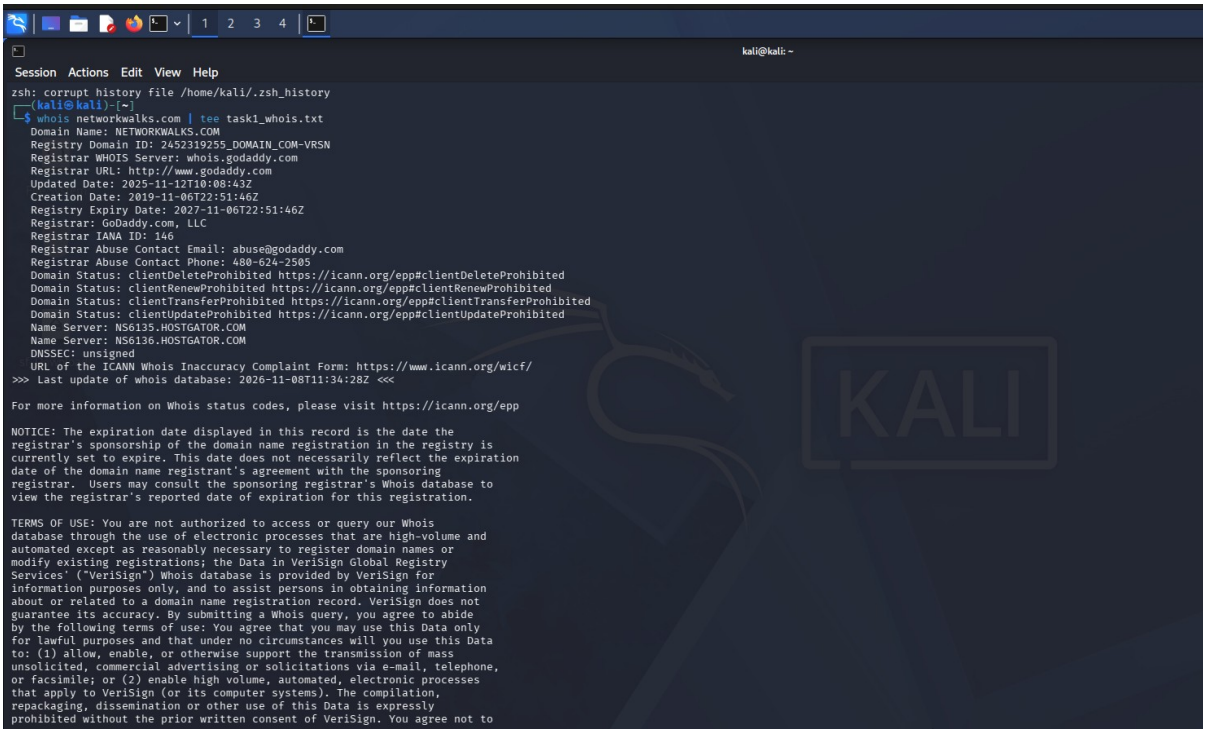
Task 1: WHOIS Domain Lookup

Query the public domain registration record to find who owns the domain, when it was registered, and its name servers.

Command

```
$ whois networkwalks.com | tee task1_whois.txt
```

Evidence



Key Findings

Field	Value
Registrar	GoDaddy.com, LLC (IANA ID 146)
Creation date	2019-11-06
Registry expiry date	2027-11-06
Last updated	2025-11-12
Name servers	NS6135 / NS6136.HOSTGATOR.COM, NS29 / NS30.DOMAINCONTROL.COM
DNSSEC	Unsigned
Domain status	Transfer / update / renew / delete locked (registrar lock)
Registrant	Hidden — Domains By Proxy, LLC (WHOIS privacy enabled)
Abuse contact	abuse@godaddy.com, +1 480-624-2505

How Attackers Use This

whois reveals the registrar, registration and expiry dates, and the domain's name servers. The HostGator name servers immediately tell an attacker the hosting provider, and the registration/abuse details support social engineering and planning for later stages of an engagement.

Defensive Observation

WHOIS privacy (Domains By Proxy) hides the actual registrant's identity, which is a good practice. DNSSEC is unsigned, meaning DNS responses are not cryptographically protected against spoofing — this is a defensive gap worth flagging.

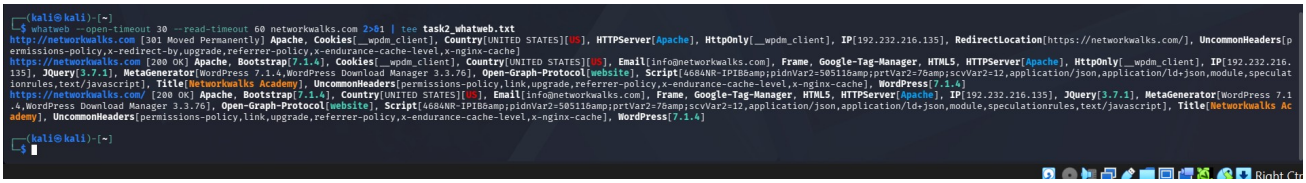
Task 2: WhatWeb Technology Fingerprint

Fingerprint the technologies running on the website: web server, CMS, plugins, frameworks and IP address.

Command

```
$ whatweb --open-timeout 30 --read-timeout 60 networkwalks.com 2>&1 | tee task2_whatweb.txt
```

Evidence



Key Findings

Field	Value
Web server	Apache
CMS	WordPress 7.1.4
Plugin	WordPress Download Manager 3.3.76
Frontend libraries	Bootstrap, jQuery 3.7.1, HTML5
Third-party	Google Tag Manager, Open Graph protocol
Server IP	192.232.216.135
Contact email	info@networkwalks.com
Page title	Networkwalks Academy
Redirect behaviour	http:// returns 301 to https://networkwalks.com/

How Attackers Use This

whatweb exposes the exact CMS and plugin versions running on the site. An attacker looks these versions up in vulnerability databases (CVE, WPScan) to find known, unpatched exploits. It also leaks the server's real IP address and a contact email that could be used for phishing.

Defensive Observation

The HTTP-to-HTTPS redirect is a good practice. However, the exposed WordPress and plugin version numbers are a risk if those components are not kept patched, regardless of any firewall in front of the site.

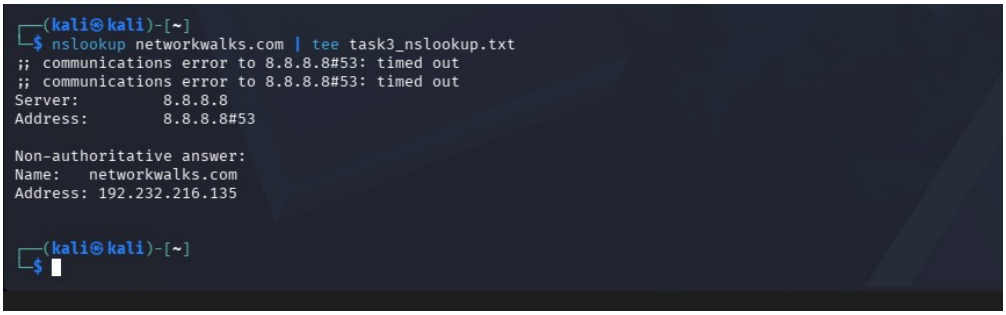
Task 3: NSLOOKUP DNS Resolution

Resolve the domain name to its IP address using DNS.

Command

```
$ nslookup networkwalks.com | tee task3_nslookup.txt
```

Evidence



Key Findings

Field	Value
DNS server used	8.8.8.8 (Google Public DNS)
Resolved IP	192.232.216.135
Answer type	Non-authoritative (served from resolver cache)

How Attackers Use This

nslookup turns a domain name into its real IP address. Knowing the IP lets an attacker scan the server directly, check for other sites sharing the same address (a sign of shared hosting), and begin mapping the target's infrastructure.

Defensive Observation

The resolved IP matches the one found independently via whatweb, confirming the result. No DNS anomalies were observed in this step.

Task 4: cURL HTTP Response Headers

Read the HTTP response headers to see the server banner, status, cookies and redirects.

Command

```
$ curl -I https://networkwalks.com | tee task4_curl.txt
```

Evidence



Key Findings

Field	Value
Status	HTTP/2 200 OK
Server banner	Apache
Cookie	__wpdm_client (secure, HttpOnly)
Cache headers	x-nginx-cache: WordPress, x-endurance-cache-level: 0
Referrer policy	no-referrer-when-downgrade
Exposed endpoint	WordPress REST API at /wp-json/ (via Link header)
Missing headers	No HSTS, X-Frame-Options, X-Content-Type-Options or CSP observed

How Attackers Use This

HTTP headers leak the web server software, the caching stack, and hidden endpoints, here the WordPress REST API at /wp-json/, without the attacker ever loading the full page. The Link header alone can be used to enumerate site content via the API.

Defensive Observation

The session cookie correctly uses the secure and HttpOnly flags. However, several modern security headers (HSTS, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy) were not present in the response — a gap worth recommending the client close.

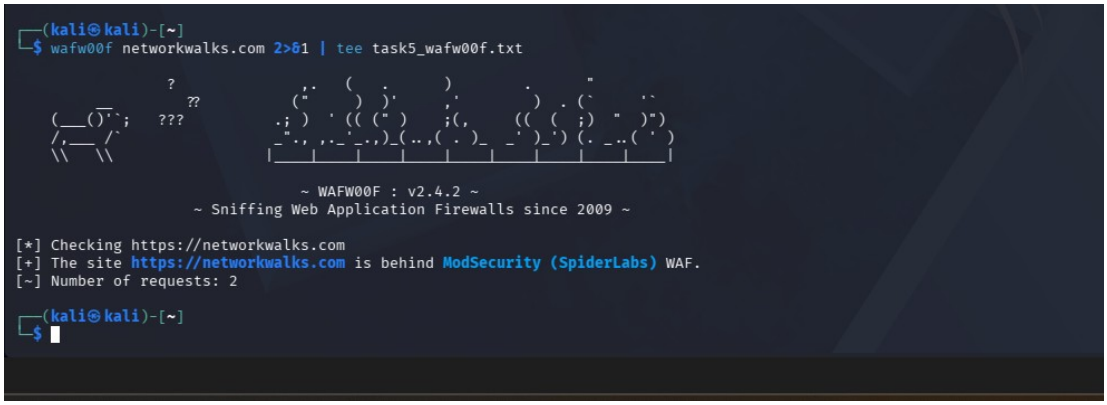
Task 5: WAFW00F Firewall Detection

Detect whether a Web Application Firewall (WAF) is protecting the target site.

Command

```
$ wafw00f networkwalks.com 2>&1 | tee task5_wafw00f.txt
```

Evidence



Key Findings

Field	Value
Tool version	wafw00f v2.4.2
WAF detected	ModSecurity (SpiderLabs)
Requests sent	2

How Attackers Use This

wafw00f tells an attacker whether a firewall is actively watching requests. Here the site sits behind ModSecurity, so an attacker knows naive attack attempts are likely to be blocked or logged, and must plan to evade or work around the WAF.

Defensive Observation

The presence of ModSecurity is a positive defensive control. It was identified with only two requests, showing how easily a WAF's presence (though not necessarily its full ruleset) can be fingerprinted from outside. A WAF reduces risk but does not replace timely patching of the underlying CMS and plugins.

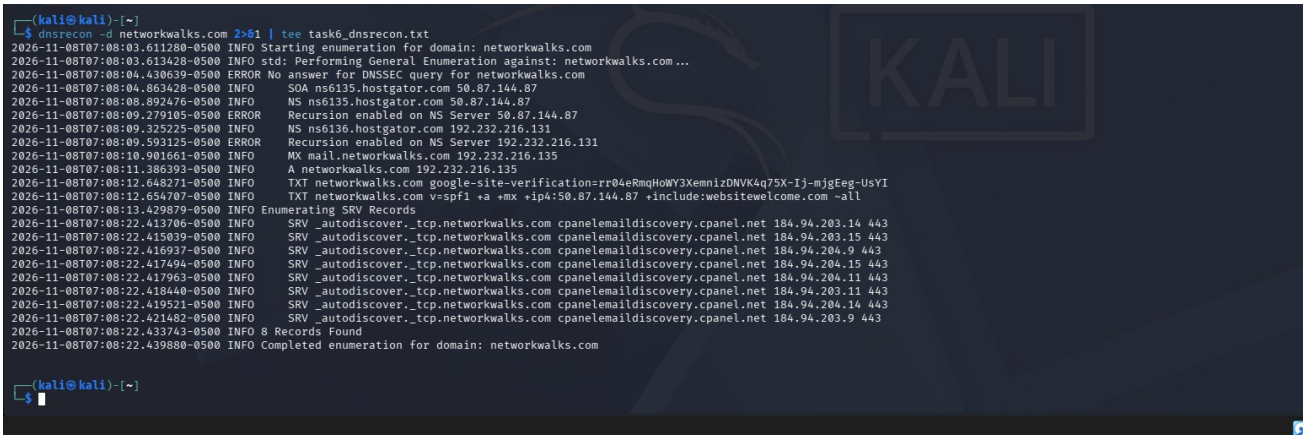
Task 6: DNSRecon Full DNS Enumeration

Enumerate all DNS records: name servers, mail servers, SPF, TXT and service (SRV) records.

Command

```
$ dnsrecon -d networkwalks.com 2>&1 | tee task6_dnsrecon.txt
```

Evidence



Key Findings

Record	Value
SOA	ns6135.hostgator.com (50.87.144.87)
NS	ns6135.hostgator.com, ns6136.hostgator.com
MX	mail.networkwalks.com (192.232.216.135)
TXT (SPF)	v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all
TXT (other)	Google site-verification record
SRV	8 _autodiscover._tcp records → cpanelemaildiscovery.cpanel.net
Total records found	8

How Attackers Use This

dnsrecon maps the target's entire DNS footprint in one pass: mail servers, SPF policy, and cPanel service records. Each record is a potential foothold, and together they help an attacker understand the hosting and email setup in detail.

Defensive Observation

Both authoritative name servers responded as open DNS resolvers ("Recursion enabled"), which is a notable finding — recursive-capable public-facing name servers can be abused for DNS amplification attacks and should be restricted to authoritative-only responses. The SPF record also ends in a soft-fail (~all) rather than a hard-fail (-all), meaning spoofed mail is flagged but not rejected outright.

Summary of Findings

The six tools together build a consistent profile of networkwalks.com without ever directly contacting or authenticating to the target beyond normal web requests:

- Ownership & hosting: Registered via GoDaddy, hosted on HostGator shared hosting infrastructure.
- Server address: 192.232.216.135, confirmed independently by nslookup, whatweb and dnsrecon.
- Technology stack: Apache web server running WordPress 7.1.4 with the WordPress Download Manager 3.3.76 plugin.
- Protection: Site is behind a ModSecurity (SpiderLabs) Web Application Firewall.
- DNS posture: Both name servers allow open recursion; DNSSEC is not enabled; SPF uses a soft-fail policy.

Defensive Recommendations

- Keep WordPress core and all plugins (especially WordPress Download Manager) patched and updated promptly, since exact version numbers are trivially discoverable.
- Disable open DNS recursion on the authoritative name servers, or restrict it to internal/trusted clients only, to prevent abuse in DNS amplification attacks.
- Enable DNSSEC to protect DNS responses against spoofing.
- Add missing HTTP security headers: HSTS, X-Frame-Options, X-Content-Type-Options, and a Content-Security-Policy.
- Tighten the SPF record from a soft-fail (~all) to a hard-fail (-all) once mail flows are fully validated.
- Continue using WHOIS privacy and keep the ModSecurity WAF active and its rule set current.

Conclusion

This exercise demonstrates why footprinting is considered the most powerful and hardest-to-detect stage of a real attack: every finding above came from information the target itself made public, without a single exploit attempt or authentication bypass. The same six tools used here to build an attacker's view of networkwalks.com are equally valuable to defenders, who can run them against their own infrastructure to see exactly what is exposed and close the gaps before an adversary finds them.

All raw command outputs are saved in task1_whois.txt through task6_dnsrecon.txt, and all terminal screenshots are embedded above as evidence for this report.